

FINAL PROJECT DUE JUNE 18, 2026 by 4PM

1 Directions

Given the protocol specification and scenario below, model the protocol in CPSA and state if the protocol fits the use case in the scenario and why. Then, state if either you believe the protocol satisfies the lab's security goals, or the protocol includes issues/attacks which compromise the goals.

2 Deliverables

1. A functioning CPSA model of the protocol described in the spec below. Your model should be able to be compiled and ran on any system. The shapes it produces should be the same shapes used in the following deliverables.
2. Prepare a brief 5-10 minute presentation that includes a brief description of the protocol, screenshots of the shapes your CPSA model produced, and a high-level description of your analysis. Be prepared to present this on the last day of the workshop!
3. You should also prepare a writeup, approximately one page in length, that describes the protocol, whether the protocol is a good fit for the scenario, and its adherence to security goals in the scenario. You should include some pictures of your shapes in the writeup (this will help you fill the page). You should also include a works cited for any materials that you reference. This may include the workshop slides, the CPSA manual, and any other CPSA code that you inspect. You should make an attempt to decide which assumptions make sense in this scenario and clearly state your reason for why in your write up.

3 Protocol Specification:

```
;; S, C, AS      : principal
;; N1, N2, N3,   : nonce
;; TS            : timestamp
;; L             : lifetime
;; pk, sk        : principal —> keypair

;; C -> AS       : C, S, N1
;; AS -> C       : AS, {AS, C, N1, pk(S)}sk(AS)
;; C -> S       : C, S, {C, TS, L, {N2}pk(S)}sk(C)
;; S -> AS       : S, C, N3
;; AS -> S       : AS, {AS, S, N3, pk(C)}sk(AS)
;; S -> C       : S, C, {S, cat(N2, ``1'')}pk(C)
```

There are four participants in this protocol:

1. Server S
2. Client C
3. Authentication Server AS
4. User U

The User is in charge of the Client, and executes all Client actions.

The User must instruct the Client C to send their own identity, the identity of the Server, and a uniquely generated nonce to the Authentication Server AS. The Authentication Server returns to the Client C the identity of the AS, and an identity package encrypted under the secret key of the AS including: the identity of the AS, the identity of the Client, the Client's nonce, and the public key of the Server. The User may inspect the data returned to the Client C if desired. The Client C sends to the Server the identity of the Client C, the identity of the Server S, and a payload encrypted under the secret key of the Client C containing: the identity of the Client C, a timestamp, an expiration time, and a uniquely generated signed nonce. The Server S then sends the AS the identity of the Server S, the identity of the Client C, and another uniquely generated nonce.

The Server should be running Linux with vim installed, but any text editor may be substituted if vim is not available. The Server is an independent distributed subsection of the protocol. A conforming Server shall not pass its authority on to any other principle. The Server shall send any messages it has the responsibility of sending. The Server shall receive and process any and all messages it has the responsibility of receiving and processing.

The AS returns to the Server S the identity of the AS, and an identity package encrypted by the AS including: the identity of the AS, the identity of the Server S, the nonce from the Server S, and the public key of the Client C. The Server S then returns to the Client C the identity of the Server S, the identity of the Client C, and a signed payload including: the identity of the Server S and the nonce sent by the Client C concatenated with the string literal "1".

All nonces must be freshly generated and unique.

All parties must not reveal their secret/private keys.

4 Scenario:

You are a Researcher in the UMBC Protocol Analysis Lab. The lab is developing a distributed storage network in which students must mutually authenticate with data storage servers.

Since many students are using the servers, pre-sharing symmetric keys across every pairing is infeasible. To manage key distribution, our lab has designed a custom protocol using an authentication server that acts as an authority on the system. The goal of this protocol is to verify the identities of both parties using public-key cryptography, establish a fresh session key, and prevent replay attacks using timestamps and lifetimes.

Before this protocol is cleared for use in the lab, the PAL Education team has assigned the lab to conduct a formal-methods analysis on it. You must determine if this design fulfills the security goals for the lab and/or if there are any attacks or flaws on the system.

5 Submission

A form will be available on the GitHub page in the **final project** directory.

When submitting make sure to include your CPSA model file, a write up on your work (including a works cited), and your slides. You must include your produced shapes in your write up which could be done by importing the images or the text output.

Your main references will be the manual, previous slides in the workshop, any related papers on CPSA or protocol analysis, and your partner. Please attempt to do this project without other human or AI help, besides your partner and instructors.